

Relatório de Auditoria de Segurança

— Casa da Paz Management System Cloud —

Data: 01/09/2026

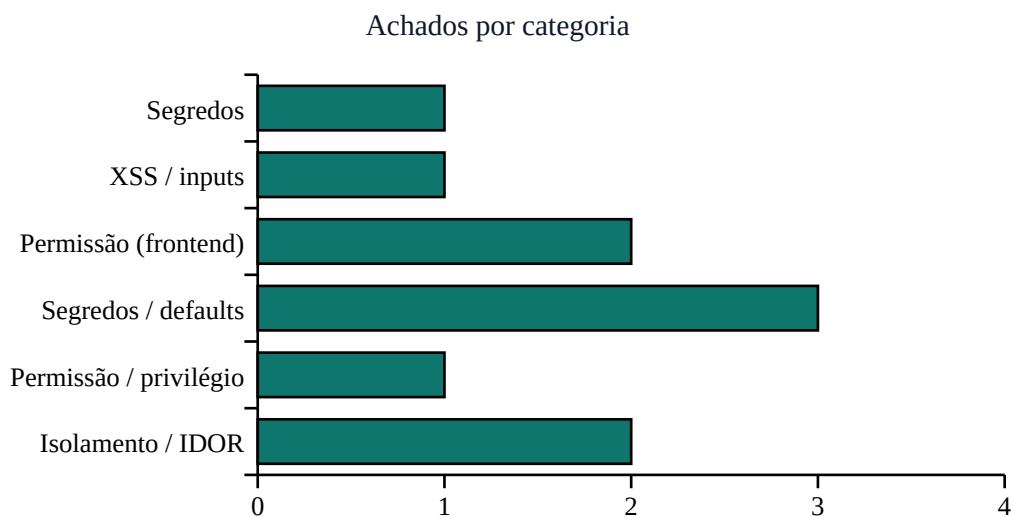
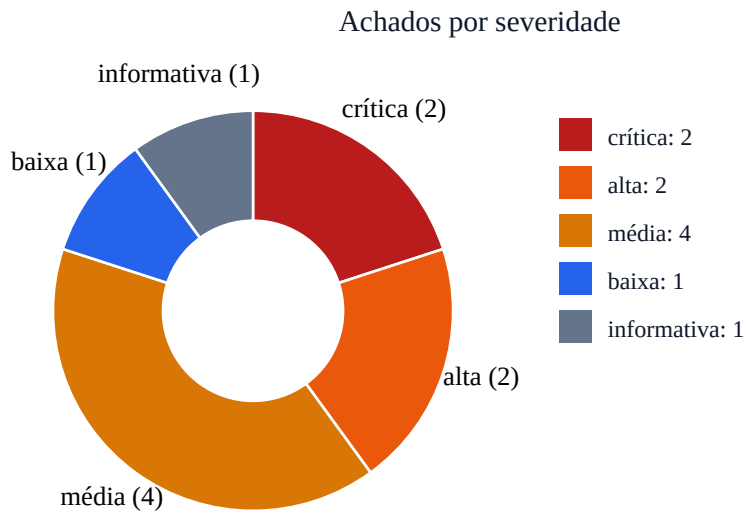
Escopo: Backend Express/Prisma · Frontend React/Vite · Docker/CI · secrets · XSS

Nota metodológica

Stack detectada: **React/Vite/TypeScript + Express/Prisma/PostgreSQL** + Docker Compose / scripts CI. Isolamento = **JWT + RBAC** (`authorize`) e filtro **own** por `pessoa_id` (casa single-tenant; não há Supabase RLS). Categorias: (1) furo em own-scope/listagens; (2) gates FE vs authorize BE; (3) IDOR por ID em todos os routers; (4) secrets/defaults compose/CI; (5) XSS (`dangerouslySetInnerHTML`, markdown, URLs). Somente achados verificados no código; pontos fortes documentam cobertura.

1. Resumo executivo

Foram identificados **10 achados** verificados: 2 crítica(s), 2 alta(s), 4 média(s), 1 baixa(s), 1 informativa(s).



2. Pontos fortes

- Isolamento: JWT + RBAC authorize + own por pessoa_id (single-tenant). Não Supabase RLS.
- Cobranças: own força filtro; pessoald da query é ignorado quando own (cobrancas.ts).
- denyOwnOrgWide em dashboard/métricas; meu-painel só self.
- Mutações financeiras pontuais usam canAccessPessoald; delete bloqueado para own.
- Histórico GET /financeiro/pessoas/:pessoald/historico valida canAccessPessoald.
- Usuários: authorize + canManageTargetUser; auditoria requireSupervisor.
- Webhooks Asaas/PIX fail-closed em produção + timing-safe.
- resolveSecret rejeita defaults listados em NODE_ENV/CASADAPAZ_ENV=production.
- compose.prod.yml exige JWT_SECRET sem default inline.
- Helmet + CSP nginx; .env gitignored; sem API keys live em arquivos rastreados.
- Frontend: zero dangerouslySetInnerHTML/eval; React escapa texto (ex.: materiais de estudo).
- Maioria das rotas API: authenticate + authorize de forma consistente.

3. Pontos fracos (riscos centrais)

- **IDOR financeiro:** GET listagem permite MEDIUM ler lançamentos de outro via pessoaId.
- **Privilégio estoque:** responsável de limpeza sobe para write org-wide.
- **Defaults de segredo:** dev-secret fora da denylist; N8N sem resolveSecret.

4. Achados detalhados

Sev.	Arquivo:linha	Descrição
CRÍTICA	backend/■src/■lib/■listagem-financeiro.ts:105-110	F01 — Query pessoald sobrescreve escopo own na listagem financeira buildListagemWhere copia o scope (own → {pessoald do JWT}) e depois sobrescreve base.pessoald com filtros.pessoald da query, sem validar igualdade. <i>Explorável:</i> MEDIUM com financeiro:own autentica e chama GET /api/financeiro?pessoald= para listar lançamentos alheios.
CRÍTICA	backend/■src/■routes/■financeiro.ts:130-138	F02 — GET /api/financeiro propaga pessoald da query para buildListagemWhere Handler autenticado com authorize(financeiro,read) passa parseListagemQuery (inclui pessoald) e mediumScope(req) para buildListagemWhere — vetor de F01. <i>Explorável:</i> Mesmo vetor de F01 via endpoint de listagem.
ALTA	backend/■src/■routes/■estoque-casa.ts:68-84, 109-110	F03 — Responsável de limpeza recebe write org-wide em estoque_casa requireEstoqueCasa chama assertEstoqueCasaAccess sem grupold. isResponsavelGrupoLimpeza(userId) sem grupold = qualquer grupo ativo. enrichEstoqueCasaGrants também promove a write (estoque-casa.ts lib:27-28). <i>Explorável:</i> Médio responsável de limpeza sem policy estoque_casa:write cria/altera itens e movimentações (POST /itens, POST /movimentacoes).
ALTA	infra/■docker-compose.yml + runtime-env.ts:compose:32; runtime-env:3-8	F04 — JWT default 'dev-secret' fora da denylist de produção docker-compose.yml usa JWT_SECRET=\${JWT_SECRET:-dev-secret}. DEV_DEFAULTS em runtime-env.ts lista 'dev-secret-change-me' mas NÃO 'dev-secret'. check-prod-secrets.sh também omite 'dev-secret'. compose.prod exige JWT sem default (mitigação parcial se só prod for usado). <i>Explorável:</i> Ambiente com CASADAPAZ_ENV/NODE_ENV=production e JWT_SECRET=dev-secret (copiado do compose de dev) passa resolveSecret e permite forjar JWTs.
MÉDIA	backend/■src/■lib/■n8n.ts:28	F05 — Fallback n8n-dev-secret sem resolveSecret no outbound N8N dispararN8n usa process.env.N8N_WEBHOOK_SECRET ?? 'n8n-dev-secret' sem resolveSecret. Em produção sem env, envia header com segredo público para o webhook N8N (se N8N_URL estiver setado). <i>Explorável:</i> Atacante que conhece n8n-dev-secret pode forjar chamadas se o N8N confiar no header.
MÉDIA	backend/■prisma/■seed.ts:95, 104	F06 — Senhas padrão de seed documentadas (admin123 / supervisor123) Seed cria admin/supervisor com senhas conhecidas, repetidas em README e runbooks. Risco residual se seed rodou em produção sem rotação. <i>Explorável:</i> Login com credenciais públicas se contas seed permanecerem ativas.
MÉDIA	frontend/■src/■App.tsx:93-112	F07 — Sub-rotas financeiras sem RequireRole por recurso Pai /app/financeiro exige só financeiro:read. Filhos ofx, contas-pagar, dre, recorrencia, contribuintes, contas NÃO têm RequireRole próprio (diferente de cobrancas/transparencia/alertas). FinanceiroLayout só esconde abas. RequireRole checka apenas 'read' (guards/RequireRole.tsx:28). <i>Explorável:</i> Usuário com financeiro:read abre /app/financeiro/ofx etc. por URL. API ainda deve 403 — defesa em profundidade incompleta no FE.
MÉDIA	frontend/■src/■pages (Marketing / Ecommerce):RequireRole read-only	F08 — UI de escrita sem gate write em marketing e ecommerce RequireRole só valida read. Páginas marketing/ecommerce expõem formulários de mutação a quem tem apenas read (confirmado: sem hasPermission write nessas páginas). <i>Explorável:</i> Qualquer marketing:read vê e tenta POST/PATCH; BE deve negar.
BAIXA	frontend (invoiceUrl / imagemUrl):vários	F09 — URLs de API em href/src sem allowlist de esquema Sem dangerouslySetInnerHTML/eval (ponto forte). invoiceUrl e imagemUrl vão para href/src sem validar http/https — risco phishing/open-redirect, não XSS clássico via React text. <i>Explorável:</i> Se API/DB armazenar javascript: ou URL maliciosa, link/imagem abusável.
INFORMATIVA	infra/■scripts/■check-prod-secrets.sh:13	F10 — Script CI/VPS alinhado à denylist incompleta (mesmo tema F04) DEV_BAD omite 'dev-secret' e 'changeme' usados em compose de desenvolvimento. <i>Explorável:</i> Gate pode aprovar JWT_SECRET=dev-secret se presente no .env.production.

5. Evidências por achado

F01 — Query pessoald sobrescreve escopo own na listagem financeira [CRÍTICA]

Arquivo: backend/src/lib/listagem-financeiro.ts:105-110 | Categoria: 1. Isolamento / IDOR

Código: const base = { ...scope }; ... if (filtros.pessoaId) base.pessoaId = filtros.pessoaId;

Impacto: Quebra de confidencialidade financeira entre médiuns (IDOR).

Correção: Se scope já define pessoald, ignorar filtros.pessoald ou exigir igualdade (403 se divergir). Teste de regressão obrigatório.

F02 — GET /api/financeiro propaga pessoald da query para buildListagemWhere [CRÍTICA]

Arquivo: backend/src/routes/financeiro.ts:130-138 | Categoria: 1. Isolamento / IDOR

Código: buildListagemWhere(parsed, mediumScope(req));

Impacto: Exposição de dados financeiros de terceiros via API.

Correção: Não passar pessoald da query quando reqIsOwnScope; ou validar no handler.

F03 — Responsável de limpeza recebe write org-wide em estoque_casa [ALTA]

Arquivo: backend/src/routes/estoque-casa.ts:68-84, 109-110 | Categoria: 2. Permissão / privilégio

Código: return isResponsavelGrupoLimpeza(user.userId, grupoId); // grupoId omitido

Impacto: Elevação de privilégio — integridade do estoque da casa.

Correção: Bypass só em rotas de checklist do próprio grupo; itens/mov exigem authorize('estoque_casa','write').

F04 — JWT default 'dev-secret' fora da denylist de produção [ALTA]

Arquivo: infra/docker-compose.yml + runtime-env.ts:compose:32; runtime-env:3-8 | Categoria: 4. Segredos / defaults

Código: JWT_SECRET: \${JWT_SECRET:-dev-secret} // DEV_DEFAULTS sem 'dev-secret'

Impacto: Comprometimento de autenticação se default for usado em runtime prod.

Correção: Incluir 'dev-secret' e 'changeme' na denylist; alinhar check-prod-secrets.sh.

F05 — Fallback n8n-dev-secret sem resolveSecret no outbound N8N [MÉDIA]

Arquivo: backend/src/lib/n8n.ts:28 | Categoria: 4. Segredos / defaults

Código: const secret = process.env.N8N_WEBHOOK_SECRET ?? 'n8n-dev-secret';

Impacto: Integridade de automações N8N em ambientes mal configurados.

Correção: Usar resolveSecret('N8N_WEBHOOK_SECRET', 'n8n-dev-secret'); fail-closed se N8N ativo.

F06 — Senhas padrão de seed documentadas (admin123 / supervisor123) [MÉDIA]

Arquivo: backend/prisma/seed.ts:95, 104 | Categoria: 4. Segredos / defaults

Código: senha: 'admin123' / senha: 'supervisor123'

Impacto: Acesso privilegiado residual pós-bootstrap.

Correção: Forçar troca no 1º login; senhas aleatórias em prod; checklist de rotação.

F07 — Sub-rotas financeiras sem RequireRole por recurso [MÉDIA]

Arquivo: frontend/src/App.tsx:93-112 | Categoria: 2. Permissão (frontend)

Código: } /> // sem RequireRole

Impacto: UX/erro e superfície se API falhar; alinhamento FE↔BE incompleto.

Correção: Espelhar resource:read em cada sub-rotas; gates write no FE onde houver mutação.

F08 — UI de escrita sem gate write em marketing e ecommerce [MÉDIA]

Arquivo: frontend/src/pages (Marketing / Ecommerce):RequireRole read-only | Categoria: 2. Permissão (frontend)

Código: RequireRole → hasPermission(..., 'read') apenas

Impacto: Defesa em profundidade; depende 100% do authorize no backend.

Correção: Ocultar ações write com hasPermission(resource,'write'); manter authorize no BE.

F09 — URLs de API em href/src sem allowlist de esquema [BAIXA]

Arquivo: frontend (invoiceUrl / imageUrl):vários | **Categoria:** 5. XSS / inputs

Código: href={c.invoiceUrl} / src={imageUrl}

Impacto: Phishing ou esquema perigoso; XSS clássico não evidenciado.

Correção: Helper safeUrl() com allowlist http/https.

F10 — Script CI/VPS alinhado à denylist incompleta (mesmo tema F04) [INFORMATIVA]

Arquivo: infra/scripts/check-prod-secrets.sh:13 | **Categoria:** 4. Segredos

Código: DEV_BAD=("dev-secret-change-me" "asaas-dev-webhook-token" ...)

Impacto: Falha de gate de deploy (agrupado com F04).

Correção: Expandir DEV_BAD; falhar pipeline.

6. Recomendações priorizadas

- P1** — Corrigir sobrescrita de pessoald em buildListagemWhere + teste (F01/F02).
- P1** — Restringir bypass limpeza em estoque_casa às rotas de checklist (F03).
- P1** — Incluir 'dev-secret' na denylist; resolveSecret no N8N outbound (F04/F05/F10).
- P2** — Rotacionar senhas seed; RequireRole por sub-rota financeira (F06/F07).
- P2** — Gates write no FE para marketing/ecommerce (F08).
- P3** — Allowlist de esquema em href/src (F09).

7. ISSUES PARA O GITHUB

Copie cada bloco para criar issues. Labels: **security** + severidade.

```

--- ISSUE 1 ---
Título: [Segurança] IDOR: MEDIUM lista financeiro de outro médium via ?pessoaId=
Labels: security, crítica
Achados: F01, F02

## Problema
`buildListagemWhere` sobrescreve o filtro de escopo `own` com `pessoaId` da query.

## Por que é explorável
1. Autenticar como MEDIUM com `financeiro: own`.
2. `GET /api/financeiro?pessoaId=<id_de_outro>`.
3. Lista lançamentos do outro médium.

## Evidência
- `backend/src/lib/listagem-financeiro.ts:105-110`
- `backend/src/routes/financeiro.ts:130-138`

```ts
const base: Prisma.FinanceiroTransacaoWhereInput = { ...scope };
if (filtros.pessoaId) base.pessoaId = filtros.pessoaId;
```

## Impacto
Confidencialidade financeira entre médiuns.

## Sugestão
Quando `scope.pessoaId` estiver definido, ignorar query ou retornar 403 se divergir.

## Critérios de aceite
- [ ] MEDIUM own + `?pessoaId=<outro>` → 403 ou só dados próprios
- [ ] Staff continua filtrando por pessoaId
- [ ] Teste automatizado de regressão

--- FIM ISSUE 1 ---

--- ISSUE 2 ---
Título: [Segurança] Elevação: responsável limpeza tem write org-wide em estoque_casa
Labels: security, alta
Achados: F03

## Problema
`assertEstoqueCasaAccess` sem `grupoId` libera qualquer responsável de limpeza para CRUD de itens/
movimentações.

## Evidência
- `backend/src/routes/estoque-casa.ts:68-84, 109-110`
- `backend/src/lib/estoque-casa.ts:5-15, 27-28`

## Impacto
Integridade do inventário da casa.

## Sugestão
Bypass só em checklist do grupo; itens/mov com `authorize('estoque_casa','write')`.

## Critérios de aceite
- [ ] Responsável limpeza: checklist OK; POST item/mov → 403 sem policy
- [ ] Staff/policy write: fluxo completo OK

--- FIM ISSUE 2 ---

--- ISSUE 3 ---
Título: [Segurança] Defaults públicos JWT/N8N fora da denylist / sem resolveSecret
Labels: security, alta
Achados: F04, F05, F10

## Problema
`dev-secret` (compose) não está em DEV_DEFAULTS/DEV_BAD. Outbound N8N faz fallback `n8n-dev-secret`
sem `resolveSecret`.

## Evidência

```



```
- `infra/docker-compose.yml:32` - `JWT_SECRET:-dev-secret`  
- `backend/src/lib/runtime-env.ts:3-8`  
- `backend/src/lib/n8n.ts:28`  
- `infra/scripts/check-prod-secrets.sh:13`
```

Impacto

JWT forjável / webhook N8N autenticável se defaults forem a produção.

Sugestão

Expandir denylist; `resolveSecret` no N8N; falhar boot/CI.

Critérios de aceite

- [] Boot prod com `JWT\_SECRET=dev-secret` falha
- [] N8N sem secret forte não usa fallback em prod
- [] `check-prod-secrets.sh` detecta `dev-secret`

--- FIM ISSUE 3 ---

--- ISSUE 4 ---

Título: [Segurança] Endurecer seed + RequireRole nas sub-rotas financeiras e write UI

Labels: security, média

Achados: F06, F07, F08

Problema

Senhas seed conhecidas; sub-rotas FE financeiras sem gate por recurso; marketing/ecommerce write UI só com read.

Evidência

- `backend/prisma/seed.ts:95,104`
- `frontend/src/App.tsx:93-112`
- `frontend/src/guards/RequireRole.tsx:28`

Sugestão

Rotação forçada; RequireRole por recurso filho; `hasPermission(...,'write')` nas mutações FE.

Critérios de aceite

- [] Contas seed exigem troca ou desabilitadas pós-bootstrap
- [] URL `/app/financeiro/ofx` sem grant → redirect
- [] marketing:read não mostra botões de criar/editar

--- FIM ISSUE 4 ---

--- ISSUE 5 ---

Título: [Segurança] Allowlist de esquema em URLs (href/src)

Labels: security, baixa

Achados: F09

Problema

invoiceUrl/imageUrl sem allowlist http(s).

Sugestão

`safeUrl()` rejeitando esquemas não http/https.

Critérios de aceite

- [] `javascript:` não vira href
- [] http/https legítimos OK

--- FIM ISSUE 5 ---